Отчет по практической работе №1

Анализ и классификация потенциальных угроз

Цель: проанализировать и классифицировать потенциальные угрозы для заданной информационной системы.

1 Описание информационной системы

Интернет-магазин — Покупатель регистрируется на сайте, выбирает товары, оформляет заказ и просматривает свои заказы. Сотрудник магазина обрабатывает заказы, а администратор управляет доступом к базе данных.

База данных хранит сведения о покупателях, товарах, заказах и оплатах. Покупателю должны быть доступны только его данные.

2 Основные активы данных

Персональные данные покупателей: имя, телефон, электронная почта и адрес доставки.

Данные учётных записей: логины, данные для проверки паролей.

Данные о заказах: какие товары заказаны, количество, сумма заказа, состояние.

Данные об оплатах: сумма оплаты, оплачен ли заказ.

Данные о товарах: названия, цены и количество товаров.

Резервные копии базы данных: копии сохранённой информации, которые нужны для восстановления после сбоя.

3 Категории угроз:

Конфиденциальность: данные видят только те, кому разрешён доступ.

Целостность: данные остаются правильными и полными.

Доступность: пользователи могут получить нужные данные вовремя.

4 Потенциальные угрозы и возможные векторы атак:

Конфиденциальность: Персональные данные и заказы других покупателей. Покупатель входит в свою учетную запись, но из-за ошибки получает возможность просматривать данные другого покупателя, или злоумышленник, который получил доступ к данным других покупателей

Целостность: Изменения данных о заказах. Доступ к изменению таблицы заказов, полученный через уязвимость или лишние права. Злоумышленник меняет сохранённую сумму заказа в свою пользу.

Доступность: Данные о товарах, заказах и оплатах, к которым временно нельзя получить доступ. Массовая отправка DoS/DDoS атак, которые требуют много ресурсов сервера базы данных. За счет чего ресурсов не хватает, чтобы обработать запросы обычных покупателей